

Trial gate, landing photos, session limit and consultation CTA

Four changes, delivered together: the trial is now invite-only and metered, the landing pages have a photo showcase, the five-minute cut-off is made reliable, and every finished report ends with a route to a paid consultation.

What changed, by request

1. Access codes

Visitors must enter a code before they reach the product. Two codes, two tiers:

Tier	Code variable	Report	Sessions
Demo	<code>ACCESS_CODE_DEMO</code>	Complete, with download and print	Uncapped
Sales	<code>ACCESS_CODE_SALES</code>	Headline verdict and measurements only	One

Matching is a plain case-insensitive, whitespace-trimmed string compare, as specified.

The browser prompt is the front door, not the lock. `public/access-gate.js` covers the page so nobody sees a live product without a code, but anyone reading the page source can get past it. What actually protects the budget is server-side: `/api/conversation`, `/api/analyze` and `/api/interview-feedback` each require a session token from `/api/access`. The codes never reach the browser, and `/api/access` is rate-limited to eight attempts per IP per minute.

2. Landing-page photos

A four-image showcase with captions sits below the scenario cards on both landing pages. It ships with clearly-labelled placeholder SVGs in `public/img/`.

To use real photos: save them as `showcase-1.jpg` ... `showcase-4.jpg` in `public/img/` and update the four `src` attributes in each page. Landscape crops near 8:5 fit without cropping. A missing file degrades to a neutral tile rather than a broken image.

3. Five-minute limit

This was already built — Tavus caps the call at `max_call_duration: 300` and the in-room countdown ends the session and loads the report at zero. **One real defect was fixed:** the countdown decremented on a `setInterval`, which browsers throttle in background tabs, so a user who switched tabs got more than five minutes. It now derives the remaining time from the wall clock on every tick.

The automatic cut-off also now says "Time's up — building your report..." instead of the generic analysing message, so it reads as intentional rather than as a dropped call.

4. Consultation link

Every completed report ends with a booking card for a free consultation with a recruitment expert, linking to `CALENDLY_URL`. A prospect whose trial is spent gets the same card instead of a dead end. If `CALENDLY_URL` is unset the card is hidden rather than shown broken, and the server says so at boot.

Two decisions worth knowing about

The sales-tier report is redacted on the server, not blurred in CSS. A CSS blur leaves the full text in the DOM, in view-source, in Print / Save as PDF and in the HTML export — it would have looked gated without being gated. `redactForTier()` in `access.js` strips the withheld sections from the response, and the page renders a locked placeholder over a generated skeleton. Verified: none of the withheld text appears anywhere in the delivered page.

A sales prospect sees: the score and band, the coach's take, the summary, the four metric tiles, the real voice measurements (words per minute, pitch variation, hesitations, clarity), the transcript-derived language notes, and one strength and one improvement. Withheld: presence on camera, the voice narrative, line-by-line corrections, the model answer, and the remaining strengths and improvements — each shown as a locked card naming what is in it.

The trial run is charged inside `/api/conversation`, the moment conversational-video billing begins — not in the browser. Reloading the page cannot buy more sessions. If the call fails to start, the run is refunded rather than burning a prospect's only try on an outage.

Impact

Area	Before	After
Who can spend tokens	Anyone with the URL	Only a code holder, capped per session
Sessions per prospect	Unlimited	One, enforced server-side
Time per session	5 min, escapable by backgrounding the tab	5 min, wall-clock enforced
End of the funnel	Report, then nothing	Report, then a booking link
Report for prospects	Everything	Enough to prove it works, not enough to replace the consultation

No change to the conversation, the grading rubrics, the voice analysis, or the report for demo users.

Files

Added

File	Purpose
<code>access.js</code>	Code checking, trial sessions, run limits, report redaction

File	Purpose
<code>public/access-gate.js</code>	The code prompt, shared by both pages
<code>public/img/showcase-1..4.svg</code>	Placeholder photography

Modified

File	Change
<code>server.js</code>	<code>/api/access</code> and <code>/api/access/verify</code> ; session checks and run charging on the three spending endpoints; tier redaction; boot diagnostics
<code>public/exam.html</code>	Gate; photo showcase; wall-clock timer; tiered report with locked cards; booking card; session token on every request
<code>public/index.html</code>	Gate; photo showcase; booking card; session token on <code>/api/analyze</code> ; a link through to the live product, which it previously lacked
<code>.env /</code> <code>.env.example</code>	<code>ACCESS_CODE_DEMO</code> , <code>ACCESS_CODE_SALES</code> , <code>TRIAL_RUNS_DEMO</code> , <code>TRIAL_RUNS_SALES</code> , <code>CALENDLY_URL</code>
<code>README.md</code>	Access and trial limits section; configuration table; API table; photo-swap instructions

Before you deploy

1. **Change the codes.** `.env` currently holds placeholders — `QFWORK-DEMO-2026` and `QFWORK-TRIAL-2026`. Set your own, and set them on the host as well as locally.
2. **Set `CALENDLY_URL`.** It is blank, so the booking card is currently hidden everywhere.
3. **Swap the photos** in `public/img/` when you have them.
4. Consider whether `TRIAL_RUNS_SALES=1` is right. Two would let a prospect recover from a bad first attempt.

Known limits

- **Sessions live in server memory.** A redeploy drops them: anyone mid-trial re-enters their code, and a sales prospect could get one extra run. Costs a few sessions at most; a hard global budget per code would need a database.
- **A leaked code works until you change it.** There is no per-person identity, by design — it is a demo gate, not a login.
- **`/api/abandon` is deliberately ungated.** It only ever stops billing, and it is delivered by `sendBeacon`, which cannot set headers.

Verified

Bad codes rejected; both codes accepted including messy whitespace and casing; brute-force limiter trips at nine attempts; all three spending endpoints reject requests without a token; the run cap allows exactly one sales session and refunds a failed start; redaction strips every withheld field and leaves the original untouched; the gated report renders with locked cards, keeps its measurements, and hides

download and print; the full report is unchanged for demo users; both landing pages show the gate before any product content and the showcase after unlocking.

The live Tavus call path was not exercised end to end, since doing so bills real conversational-video minutes.